

Chính Sách Truy Cập Hệ Thống & Mạng Riêng Ảo (VPN) Nội Bộ

Mã tài liệu: IT-POL-007 **Phiên bản:** 2.4 **Ngày hiệu lực:** 01/04/2026 **Ngày rà soát tiếp theo:** 01/04/2027 **Chủ sở hữu tài liệu:** Phòng Hạ tầng & Vận hành CNTT (IT Operations) **Phê duyệt:** Giám đốc Công nghệ (CTO) — Trần Minh Khoa **Phạm vi áp dụng:** Toàn bộ nhân viên chính thức, thực tập sinh, cộng tác viên dài hạn và nhà thầu phụ của Công ty Cổ phần Công nghệ TechNova **Mức độ bảo mật tài liệu:** Nội bộ — Hạn chế (Internal — Restricted) **Vai trò được phép truy cập:** employee, hr, it

Đây là tài liệu mô phỏng được tạo ra để kiểm thử pipeline RAG nội bộ. Nội dung, tên người, số liệu là hư cấu, không phản ánh chính sách vận hành thật.

1. Mục đích và nguyên tắc cốt lõi

Chính sách này quy định cách thức cấp, quản lý, giám sát và thu hồi quyền truy cập vào hệ thống thông tin, mạng nội bộ và tài nguyên VPN của TechNova, nhằm bảo vệ tính bảo mật, toàn vẹn và khả dụng của dữ liệu công ty và khách hàng.

Nguyên tắc cốt lõi:

- Least privilege (Đặc quyền tối thiểu):** Mỗi tài khoản chỉ được cấp quyền tối thiểu cần thiết để hoàn thành công việc, không cấp quyền “phòng khi cần”.
- Need-to-know:** Quyền truy cập dữ liệu được cấp dựa trên nhu cầu công việc cụ thể, không dựa trên cấp bậc.
- Zero standing privilege cho hệ thống production nhạy cảm:** Quyền truy cập production được cấp tạm thời (just-in-time), tự động hết hạn sau khi sử dụng.
- Trách nhiệm giải trình cá nhân (Accountability):** Không chia sẻ tài khoản; mọi hành động được gắn với danh tính cá nhân qua log.
- Xác thực đa yếu tố bắt buộc (MFA-by-default):** Không có ngoại lệ cho hệ thống chứa dữ liệu khách hàng hoặc mã nguồn.

2. Phân loại tài khoản

Loại tài khoản	Mô tả	Yêu cầu phê duyệt
Tài khoản chuẩn (Standard)	Cấp cho mọi nhân viên khi onboarding: email công ty, Slack, Google Workspace, Notion (đọc).	Quản lý trực tiếp phê duyệt trong hệ thống HRIS
Tài khoản đặc quyền (Privileged)	Quyền truy cập hệ thống production, database, cụm Qdrant, secrets manager (AWS Secrets Manager / Vault).	Trưởng phòng IT + Trưởng phòng InfoSec đồng phê duyệt
Tài khoản dịch vụ (Service Account)	Dùng cho CI/CD, tích hợp API giữa các hệ thống, không gắn với cá nhân.	CTO phê duyệt, review mỗi quý
Tài khoản khách/đối tác (Guest/Partner)	Cấp tạm thời cho đối tác tích hợp, kiểm toán viên bên ngoài.	CTO phê duyệt, tối đa 30 ngày, gia hạn thủ công

3. Quy trình cấp quyền (Access Provisioning)

- Quản lý trực tiếp gửi yêu cầu qua hệ thống ticket nội bộ (Jira dự án ITSM), nêu rõ hệ thống cần truy cập, mức quyền, lý do công việc và thời hạn (nếu là quyền tạm thời).
- Đối với tài khoản chuẩn: xử lý tự động qua quy trình onboarding trong vòng 1 ngày làm việc trước ngày bắt đầu.
- Đối với tài khoản đặc quyền: yêu cầu phê duyệt hai cấp (Mục 2), xử lý trong vòng 2 ngày làm việc.
- Mọi quyền được cấp phải ghi log vào hệ thống quản lý danh tính (IdP — Google Workspace + Okta), có thể truy vết ai cấp,

- cấp cho ai, khi nào, vì lý do gì.
5. Quyền truy cập production cho kỹ sư không thuộc đội trực (on-call) mặc định ở trạng thái tắt; kích hoạt tạm thời qua công cụ just-in-time access (JIT), tự động thu hồi sau 4 giờ hoặc khi kết thúc phiên làm việc, tùy điều kiện nào đến trước.

4. Quy trình thu hồi quyền (Access Deprovisioning)

Sự kiện	Hành động	Thời hạn thực hiện
Nhân viên nghỉ việc (voluntary)	Vô hiệu hóa toàn bộ tài khoản, thu hồi thiết bị, xóa quyền VPN	Trong ngày làm việc cuối cùng
Chấm dứt hợp đồng vì lý do kỷ luật (involuntary)	Vô hiệu hóa ngay lập tức tất cả tài khoản, thu hồi thiết bị có giám sát của bảo vệ/HR	Ngay tại thời điểm thông báo, không trễ hơn 30 phút
Chuyển phòng ban / đổi vai trò	Rà soát và điều chỉnh quyền phù hợp vai trò mới, thu hồi quyền không còn cần thiết	Trong vòng 5 ngày làm việc
Nghỉ phép dài hạn (>30 ngày)	Tạm khóa tài khoản đặc quyền, giữ nguyên tài khoản chuẩn	Trước ngày bắt đầu nghỉ

HR có trách nhiệm thông báo cho IT Operations ngay khi có quyết định nghỉ việc/chuyển phòng ban thông qua kênh tích hợp HRIS → ITSM; không xử lý thủ công qua email để tránh thất lạc yêu cầu.

5. Rà soát định kỳ quyền truy cập (Access Review)

- Hàng quý:** Trưởng phòng từng bộ phận rà soát danh sách quyền truy cập của nhân viên thuộc quyền quản lý, xác nhận hoặc thu hồi quyền không còn phù hợp qua báo cáo tự động gửi từ hệ thống IdP.
- Hàng năm:** Kiểm toán toàn diện (comprehensive access audit) do Phòng InfoSec chủ trì, đối chiếu toàn bộ tài khoản đặc quyền với danh sách nhân sự hiện tại, phát hiện tài khoản “mồ côi” (orphaned account — tài khoản còn hoạt động của người đã nghỉ việc).
- Kết quả rà soát được lưu tại Notion “IT / Access Reviews”, báo cáo tóm tắt gửi Ban Giám đốc.

6. Chính sách VPN

6.1 Khi nào bắt buộc dùng VPN

VPN công ty (client: WireGuard nội bộ, gateway tại vpn.technova.vn) là bắt buộc khi truy cập:

- Database production và staging.
- Dashboard nội bộ (Grafana, Langfuse self-host, Qdrant admin UI).
- Hệ thống HRIS chứa dữ liệu lương và nhân sự.
- Mọi kết nối SSH đến máy chủ hạ tầng.

Truy cập email, Slack, Notion, Jira **không bắt buộc** VPN vì các dịch vụ này đã có xác thực MFA và giới hạn theo IP đáng tin cậy ở mức ứng dụng.

6.2 Yêu cầu kỹ thuật

- Mỗi nhân viên được cấp một chứng chỉ (certificate) VPN cá nhân, không dùng chung.
- Kết nối VPN tự động ngắt sau 8 giờ không hoạt động (idle timeout).
- Cấm sử dụng VPN cá nhân/cộng cộng khi truy cập tài nguyên nội bộ — chỉ được dùng VPN do IT cấp.
- Thiết bị kết nối VPN phải đáp ứng baseline bảo mật tối thiểu (Mục 8) được xác minh qua MDM trước khi cho phép kết nối (device posture check).

6.3 Truy cập từ xa và làm việc tại nước ngoài

Nhân viên làm việc từ xa ngoài lãnh thổ Việt Nam trên 15 ngày liên tục phải thông báo trước cho IT Operations và HR để đánh giá rủi ro (một số quốc gia có chính sách chặn VPN doanh nghiệp hoặc yêu cầu tuân thủ pháp lý riêng). Không được truy cập hệ thống production từ mạng công cộng không tin cậy (quán cà phê, sân bay) mà không qua VPN kết hợp MFA.

7. Xác thực đa yếu tố (MFA) và mật khẩu

Yêu cầu	Chi tiết
MFA bắt buộc cho	VPN, Google Workspace, GitHub tổ chức, AWS Console, hệ thống HRIS, Qdrant Cloud console
Phương thức MFA chấp nhận	Ứng dụng xác thực (Google Authenticator, Authy) hoặc security key (YubiKey). Không chấp nhận OTP qua SMS làm phương thức chính do rủi ro SIM-swap.
Độ dài mật khẩu tối thiểu	14 ký tự, khuyến khích dùng passphrase
Chu kỳ đổi mật khẩu	Không bắt buộc đổi định kỳ nếu không có dấu hiệu lộ (theo khuyến nghị NIST 800-63B hiện hành); bắt buộc đổi ngay khi có cảnh báo rò rỉ dịch vụ giám sát dark web
Quản lý mật khẩu	Bắt buộc dùng công ty cấp phát 1Password Business cho mọi mật khẩu liên quan công việc; nghiêm cấm lưu mật khẩu trong file văn bản, ghi chú trình duyệt không mã hóa

8. Chính sách thiết bị (BYOD & thiết bị công ty)

8.1 Thiết bị do công ty cấp

- Bắt buộc cài đặt phần mềm quản lý thiết bị di động (MDM — Jamf cho macOS, Intune cho Windows).
- Mã hóa ổ đĩa toàn phần bắt buộc (FileVault/BitLocker), bật tự động.
- Cập nhật hệ điều hành và bản vá bảo mật trong vòng 14 ngày kể từ khi phát hành (7 ngày đối với bản vá mức nghiêm trọng — critical).
- Cấm cài đặt phần mềm ngoài danh sách được phê duyệt (approved software list) trên máy có quyền truy cập production.

8.2 Thiết bị cá nhân (BYOD)

Chỉ cho phép BYOD truy cập email và Slack qua ứng dụng có container hóa dữ liệu công ty (Google Workspace mobile management). **Không cho phép** BYOD truy cập trực tiếp vào hệ thống production, database hoặc mã nguồn dưới bất kỳ hình thức nào, kể cả qua VPN.

9. Ghi log và giám sát

Mọi phiên VPN, phiên SSH vào hạ tầng production, và truy vấn vào database sản xuất đều được ghi log tập trung (centralized logging) và lưu tối thiểu 12 tháng, phục vụ điều tra sự cố theo tài liệu SEC-POL-014 (Quy trình xử lý sự cố bảo mật). Log bao gồm: định danh người dùng, thời gian, IP nguồn, hành động thực hiện. Nhân viên được thông báo rõ về việc giám sát này khi ký thỏa thuận sử dụng thiết bị (Acceptable Use Agreement) lúc onboarding.

10. Vi phạm chính sách

Mức vi phạm	Ví dụ	Hình thức xử lý
Nhẹ	Quên đăng xuất VPN, dùng mật khẩu yếu bị hệ thống cảnh báo	Nhắc nhở, yêu cầu đổi mật khẩu ngay
Trung bình	Chia sẻ tài khoản với đồng nghiệp, tắt MFA trái phép	Cảnh cáo bằng văn bản, tạm khóa tài khoản chờ xác minh
Nghiêm trọng	Cố ý truy cập dữ liệu không thuộc phạm vi công việc, dùng VPN cá nhân để truy cập production, cài phần mềm không được phép trên máy có quyền truy cập nhạy cảm	Xử lý kỷ luật lao động theo quy định nội bộ, có thể kèm chấm dứt hợp đồng lao động, phối hợp Phòng InfoSec mở sự cố theo SEC-POL-014 nếu nghi ngờ có thiệt hại

Mọi trường hợp vi phạm nghiêm trọng được HR Business Partner và Phòng InfoSec xử lý song song, tuân theo quy trình kỷ luật lao động quy định tại Nội quy lao động của Công ty.

11. Trách nhiệm các bên liên quan

Bên liên quan	Trách nhiệm
---------------	-------------

IT Operations	Vận hành hệ thống IdP, VPN, MDM; xử lý yêu cầu cấp/thu hồi quyền; giám sát tuân thủ baseline thiết bị
Phòng InfoSec	Định nghĩa baseline bảo mật, thực hiện kiểm toán quyền truy cập hàng năm, điều tra vi phạm
Quản lý trực tiếp	Khởi tạo và xác nhận yêu cầu quyền truy cập cho nhân viên thuộc quyền quản lý, rà soát hàng quý
HR	Đồng bộ thông tin nhân sự vào hệ thống IdP, thông báo kịp thời sự kiện nghỉ việc/chuyển đổi vai trò
Nhân viên	Tuân thủ chính sách, báo cáo ngay khi nghi ngờ tài khoản bị xâm nhập, không chia sẻ thông tin xác thực

12. Câu hỏi thường gặp (FAQ)

Hỏi: Tôi làm việc từ xa dài hạn, có cần dùng VPN suốt cả ngày không? Trả lời: Chỉ cần bật VPN khi truy cập các hệ thống liệt kê tại Mục 6.1 (database, dashboard nội bộ, SSH hạ tầng). Với công việc thông thường trên Slack/email/Notion không cần VPN.

Hỏi: Tôi cần truy cập production gấp ngoài giờ hành chính để xử lý sự cố, quy trình JIT có hoạt động 24/7 không? Trả lời: Có. Công cụ just-in-time access hoạt động 24/7; kỹ sư on-call có thể tự kích hoạt quyền tạm thời qua Slack bot /access-request, hệ thống tự log và thông báo cho Trưởng phòng IT.

Hỏi: Laptop cá nhân của tôi có được cài Slack để trả lời tin nhắn khi đi công tác không? Trả lời: Được, miễn là cài qua ứng dụng chính thức có quản lý container hóa của Google Workspace. Không được đăng nhập qua trình duyệt trên máy công cộng.

13. Rà soát và cập nhật tài liệu

Phiên bản	Ngày	Người cập nhật	Mô tả thay đổi
1.0	10/05/2023	Phạm Quốc Bảo	Ban hành lần đầu
2.0	18/11/2024	Phạm Quốc Bảo	Bổ sung chính sách just-in-time access, cập nhật yêu cầu MFA
2.3	05/08/2025	Nguyễn Hoàng Anh	Thêm chính sách BYOD chi tiết, cập nhật theo NIST 800-63B
2.4	01/04/2026	Phạm Quốc Bảo	Rà soát định kỳ hàng năm, thêm mục FAQ

Tài liệu này là dữ liệu thử nghiệm cho hệ thống RAG nội bộ. Không sử dụng cho mục đích vận hành thực tế.